

THREAT INTELLIGENCE DOSSIER

CVE-2026-25794: The UHDR Overflow

Deep-Dive into Integer Overflow & Resource Exhaustion in ImageMagick

OFFICIAL SECURITY ADVISORY | PUBLISHED MAY 2026

VULNERABILITY OVERVIEW

What is CVE-2026-25794?

A critical **Integer Overflow** vulnerability in the ImageMagick image processing suite. It occurs when the software handles the newly introduced **UHDR (Ultra High Dynamic Range)** format.

🔗 **Component:** `coders/uhdr.c` (WriteUHDRImage)

🛠️ **CWE:** CWE-190 (Integer Overflow / Wraparound)

⚠️ **Impact:** Heap Corruption & RCE



DISCOVERY & METHODOLOGY



How was it found?

The flaw was officially disclosed on **February 23, 2026**. It was identified through a proactive security audit focusing on new format decoders.

-  **Static Analysis:** Auditing arithmetic operations in `coders/uhdr.c`.
-  **Fuzzing:** Supplying malformed UHDR headers with extreme dimension values.
-  **Researcher:** GitHub Security Lab / Independent Audit.

| IMAGE FORMAT ROADMAP



HD / SHD

Focuses on **Resolution**. High Definition (720p/1080p) uses 8-bit color depth with standard dynamic range.



HDR

Focuses on **Luminance**. High Dynamic Range (10-bit+) provides 1B+ colors and higher peak brightness.



UHDR

Ultra High Dynamic Range. Google's format embedding a **Gain Map** inside a JPEG to bridge SDR and HDR.

TECHNICAL WORKING MECHANISM

The Arithmetic Flaw

The `WriteUHDRImage` function calculates the pixel buffer size using 32-bit signed `int` arithmetic. It fails to check if the product of width and height exceeds the integer's capacity.

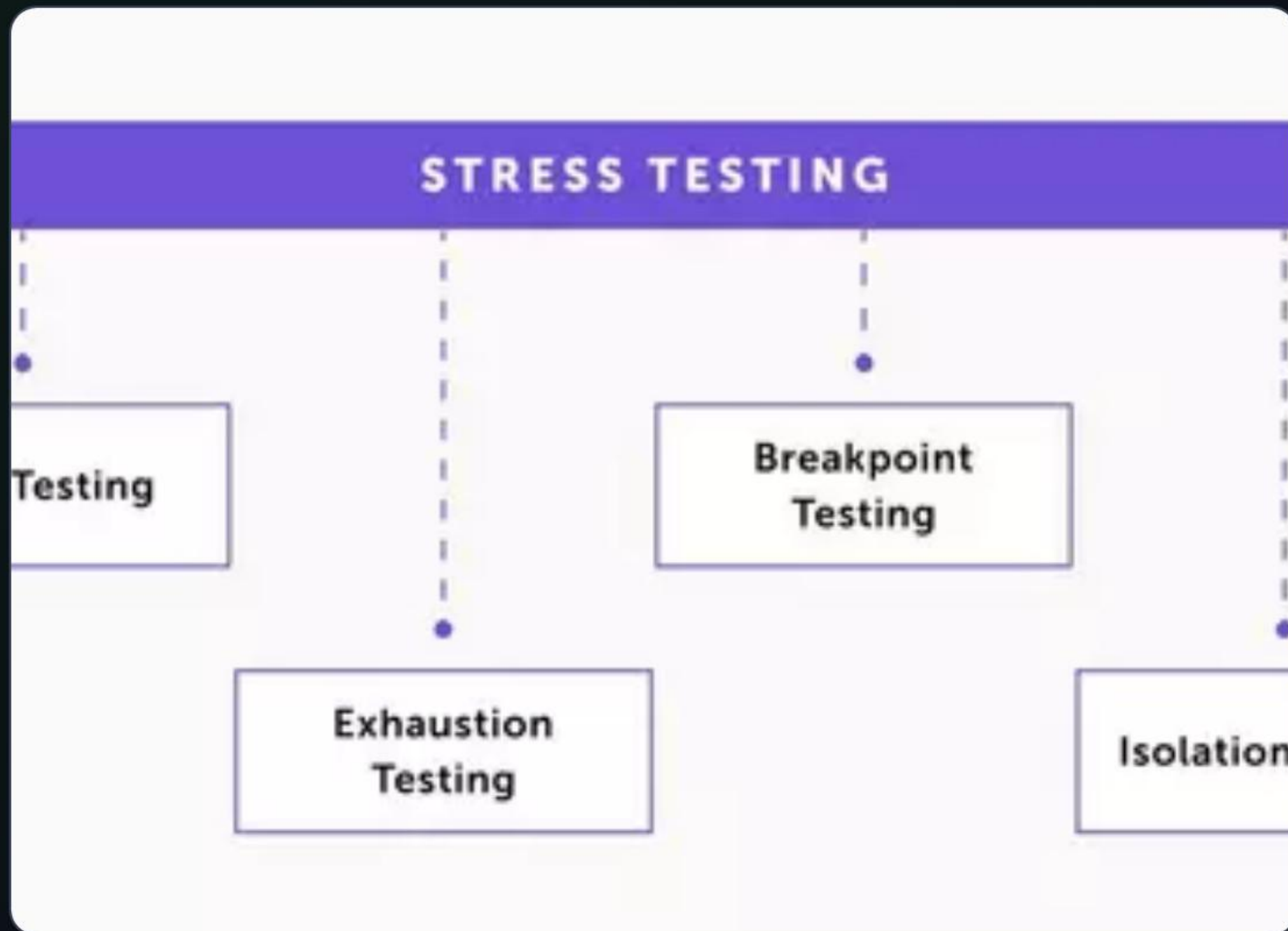
$$\text{AllocSize} = (W \cdot H \cdot 4) \bmod 2^{31}$$

When the calculation overflows, a tiny buffer is allocated for a massive dataset.

ing 7 + 1 In 2's Complir

	0	0	0	1
+	0	1	1	1
	1	0	0	0

THE "PIXEL BOMB" ATTACK



Small File, Massive Payload

An attacker creates a tiny UHDR file (KB size) but sets dimensions in the header to 100,000 x 100,000 pixels.

-  **CPU Spike:** Server attempts to compute massive pixel arrays.
-  **Memory Exhaustion:** Attempting to allocate 40GB+ of RAM causes **OOM (Out of Memory)** crashes.
-  **DoS:** Entire server resources are pinned, leading to a system-wide denial of service.

| CVSS V3.1 SEVERITY SCORE



Vulnerability requires no user interaction and can be triggered via unauthenticated image uploads.

| NVD & NIST ANALYSIS REVIEW

Official Assessment

NIST completed its review on **February 24, 2026**. The analysis emphasizes the lack of input validation in the UHDR coder.



NVD Status: ANALYZED



CWE Mappings: CWE-122 (Heap-based Buffer Overflow).



CNA: GitHub, Inc.

NIST

NVD

BUG CATEGORIZATION (P1 - P4)

Category	Impact Level	CVE-2026-25794 Status
P1 (Critical)	RCE, Unauth Access, System Takeover	 CLASSIFIED
P2 (High)	Auth RCE, Significant DoS, Data Leak	✓ Secondary Impact
P3 (Medium)	Stored XSS, CSRF, Limited Info Leak	-
P4 (Low)	Informational, Best Practices	-

EXPLOITATION ON WEBSITES

 Web Platforms

Vulnerable Environments

Websites using ImageMagick for user-provided media processing are primarily targeted:

-  **Social Media:** Profile photo & gallery uploads.
-  **CMS Platforms:** WordPress & Drupal image resizers.
-  **Media Hosting:** Sites like Imgur or Reddit-clones.

Attacks can bypass file-type filters if the server attempts to "identify" or "convert" the uploaded UHDR file.

CYBER KILL CHAIN ANALYSIS



Weaponization

Crafting a malformed UHDR file with malicious headers and embedded OOB-write payload.



Delivery

Uploading the `.uhdr` file to a public image processing endpoint on a target server.



Exploitation

Server-side ImageMagick triggers the overflow, corrupting memory to execute shellcode.

VULNERABILITY CHAINING

Beyond Initial Impact

CVE-2026-25794 is rarely used in isolation. It serves as an entry point for deeper compromise:

-  **LPE Chaining:** Once RCE is achieved, a Local Privilege Escalation exploit can be used to gain root access.
-  **Lateral Movement:** Attacking internal databases from the compromised web server.
-  **Policy Bypass:** Often used with path traversal bugs to read sensitive server configuration files.



PROOF OF CONCEPT

A POC published on Medium by Lakshan Sameera (2026) demonstrates the vulnerability using a simple python script to generate the malicious UHDR header:

```
# mal_gen.py
width = 65536
height = 65536
# Header write triggers:
# (65536 * 65536 * 4) = 0
# Allocation of 0 bytes
# Write proceeds to overwrite heap
```

Execution triggers a **SIGSEGV** or arbitrary code execution.

| REMEDIATION & CRITICAL GAPS

How to Patch

The fix was applied in version **7.1.2-15** and **6.9.13-40**. It replaces 32-bit arithmetic with `size_t` (64-bit) and adds explicit overflow checks.

- 🕒 **Patch Timing:** Released Feb 27, 2026.
- ⚠️ **Gaps:** Docker images with pinned older versions remain vulnerable.
- </> **Language Wrappers:** PHP (imagick) or Ruby gems may not have updated underlying binaries yet.



The "Patch Lag"

Enterprise environments often take 30-90 days to deploy patches, leaving a massive window of vulnerability.

STRATEGIC MITIGATION



Restrict Policy

Modify `policy.xml` to disable the UHDR coder entirely if not strictly necessary for business.



Enforce Limits

Set `width` and `height` resource limits in ImageMagick's security policy to block extreme dimensions.

WAF Detection

Deploy Web Application Firewall rules to drop image uploads containing suspicious binary headers.

Questions?

CVE-2026-25794 Intelligence Report

 security-advisory.corp
 threat-intel@defense.gov

IMAGE SOURCES



Thumbnail for
imagetragick.com

<https://imagetragick.com/img/logo-medium.png>

Source: imagetragick.com



https://miro.medium.com/v2/resize:fit:1400/1*sB3kVICOmE_eBP2C3lQaJg.jpeg

Source: medium.com



<https://media.geeksforgeeks.org/wp-content/uploads/111-5.png>

Source: www.geeksforgeeks.org



Thumbnail for
solutionshub.epam.com

<https://cdn.media.amplience.net/i/epammarketplace/stress-testing-types?w=530&q=100&fmt=webp&v=436743790941>

Source: solutionshub.epam.com



<https://www.maltego.com/images/uploads/nist-nvd-logo.png>

Source: www.maltego.com



Thumbnail
for
toppng.com

<https://toppng.com/uploads/preview/social-media-icons-cloud-social-media-icon-cloud-11562920789ps0bcimdgo.png>

Source: toppng.com

| IMAGE SOURCES



Thumbnail for <https://www.visionledpro.com/uploads/image/66fa76233b667.png>

Source: www.visionledpro.com



Thumbnail for https://static.vecteezy.com/system/resources/previews/039/886/000/non_2x/security-patch-icon-line-illustration-vector.jpg

Source: www.vecteezy.com